Cover letter and point-by-point response

Paper ID 1352

Oasis: A Mutation Testing Framework for Evaluating the Semantic Quality of Infrastructure-as-Code Test Suites

Tushar Teotia, Shiven Goomer, Yash Vardhan Rawat, Minakshi Tomer, and Manoj Kumar Malik

Dear Editors, Scientific Committee, and Reviewers,

Thank you for the careful reviews and the opportunity to revise our manuscript. We have clarified the technical contribution and supported binding procedure, repaired outcome accounting, added operator-level and execution-cost tables, and separated the historical scanner and matched-case studies from the primary campaign. The revised explanation distinguishes documented configuration semantics from unvalidated real-fault representativeness. Below we reproduce all fourteen comments verbatim and identify changes by section, table and manuscript page. The manuscript ends on page 12; the page references below refer to the manuscript, not this response.

An important clarification concerns the evidence versions. The original submission's 242 generated mutants, 177 scored mutants, and 24.9% mutation score are superseded as the headline evidence by a newly documented campaign, not retrospectively relabelled or silently repaired. The frozen catalog 3 snapshot used in this revision contains 62 archived repository attempts, of which 47 supply 1,288 scored mutant cases: 115 assertion kills, 76 runtime-error kills, and 1,097 survivors. Assertion sensitivity is 8.9%; combined rejection is 14.8%. The historical catalog 2 studies and the fixed 123-case comparison retain separate sources, methods, and denominators. The selection plan, blocked scopes, excluded cases, and incomplete work are reported explicitly (Section 5.1, page 7; Table 7, page 7).

The revision presents a bounded native-suite protocol. The responses explicitly distinguish implemented module-input support and fault-model justification from the unperformed OpenTofu-specific and representative-real-fault extensions.

Reviewer 1

R1.1. The abstract needs to clarify how equivalent mutants were found and eliminated from scoring.

Response. We have clarified the abstract and the equivalence procedure. Oasis does not solve general semantic equivalence. It identifies a narrower class of selected-context no-ops through a frozen active/shadowed/unresolved binding procedure. Root-run checks are stricter than nested-caller checks: an explicit literal can remain unresolved when other inputs are expressions, and root nullable-null cases are not treated like nested nullable-null cases. On successful analysis, any active route admits native testing; only an all-shadowed record set is excluded as a no-op, with other unresolved cases kept separate. The primary ledger records 193 no-ops and 39 unresolved cases. The real Equinor example connects an active omitted-input route to an existing assertion and exact native failure diagnostic. A selected-context no-op is not global equivalence; survivors are not discarded because tests pass, static references are absent, mocks obscure the edit or a scanner is silent.

Locations. Abstract; Section 3.3, page 3, especially Table 5, page 5; Section 4.3, page 6; the source-to-oracle example on page 9; Table 7, page 7.

R1.2. Mutation testing is an old topic and adopting twelve operators for Terraform is not novel.

Response. We agree that the established mutation principle and operator count do not constitute novelty. The introduction now identifies the contribution as an explicit native-suite attribution protocol and case-linked empirical evaluation. The design explains why an overridden child default is not automatically an effective mutation and why baseline failure, invalidity, runtime rejection and assertion failure must be separated. The supported decision procedure and binding table make these cases concrete; unresolved analysis is retained rather than silently guessed. The ProTI/EMIaC comparison identifies different subjects, transformations and oracles, without claiming a controlled accuracy ranking. Catalog 3 retains twelve identifiers and adds four bounded transformations, but neither those additions nor shared-HCL execution is claimed as a new testing principle or a general semantic-equivalence algorithm.

Locations. Sections 1, 2 and 3, pages 1, 2 and 2; Tables 1 and 5, pages 2 and 5; Section 3.3, page 3.

R1.3. Sixty five out of 242 mutants remain unscored, affecting the reported mutation score.

Response. This was a material limitation of the original result. We do not claim that those 65 historical cases have all now been resolved. Instead, the revised headline result comes from a separately identified frozen campaign.

Its 1,533 generated records comprise 1,288 scored and 245 excluded cases: 193 context no-ops, 39 unresolved contexts, and 13 timeouts. Scoring uses only $N = A + E + S$; timeouts are not kills. The complete 95-identity plan contains 62 archived attempts, three preparation failures, one in-flight identity excluded from this snapshot, and 29 unrun identities. Of the archived attempts, 47 provide scored cases and 15 do not; 39 scored repositories pass every selected baseline, while eight have partial scope coverage. The 192 archived scope attempts contain 130 baseline passes and 62 blocked/unavailable baselines. Potential mutants in blocked or unrun scopes remain unknown, not imputed as survivors or successes.

Locations. Sections 4.3 and 5.1, pages 6 and 7; Tables 7 and 8, pages 7 and 7.

R1.4. Compare Oasis with policy scanners like Checkov or tfsec on the same repositories.

Response. We have included a measured tfsec 1.28.14 comparison on the same historical original 23 repository snapshots and their 276 scored catalog 2 cases. Unmutated/mutant comparisons credit only newly reported rule identifiers associated with the mutation location, not pre-existing findings. There are 231 usable comparisons and 45 unavailable comparisons, with scanner failures retained as unavailable rather than nondetections. Among usable comparisons, 126 have a new site-associated rule, including 88 native-test survivors; nine assertion kills have no new site-associated rule. These observations demonstrate different signals under the recorded conditions, not vulnerability ground truth or scanner superiority. The comparison is explicitly historical: it has not been rerun on the expanded 1,288-case primary pool. Native test inputs, scanner parsing, module handling, and location association differ, so we make no precision/recall claim. Concrete cases illustrate the distinction.

Locations. Section 4.5, page 7; the joint outcome table and historical examples in Section 5.4, page 10, including Table 15, page 10; Section 6, page 10.

R1.5. The conclusion overgeneralizes from 23 repositories; References [2] and [3] have no authors.

Response. The conclusion now limits the findings to the selected projects, recorded fixtures, bounded operators, and disclosed snapshot. The larger campaign is still a technically screened convenience sample, not a representative population study; 47 scored repositories do not establish universal adequacy or routine-adoption thresholds. Full and partial selected-baseline coverage, exclusions, and incomplete work remain visible. We have repaired the bibliography with explicit scholarly author lists and publication details, while identifying corporate-authored documentation as documentation. The entries underlying the original incomplete-reference concern have been checked rather than assuming their old numbers survive the revised bibliography order. The revised conclusion presents mutation feedback as a selective diagnostic aid and separates test sensitivity from real-fault prevalence and deployed-cloud security.

Locations. Sections 4.1, 6, and 8, pages 5, 10, and 11; Table 7, page 7; revised References at the end of the manuscript, ending on page 12.

Reviewer 2

R2.1. The abstract provides a 24.9% mutation score without specifying repository selection criteria.

Response. We have revised the abstract to identify the sample as a technically screened convenience sample and replaced the original headline score with the explicitly versioned primary results. The methods explain discovery and manual screening for native tests, mock-compatible execution, local source, and potential frozen-operator sites. Static applicability is only a screening condition; it does not establish a passing native baseline or a scored mutant. The 95-identity plan and cohort provenance are retained, including unsuccessful and unrun work. The time-based cutoff, visibility of earlier outcomes, and preference for smaller observed workloads are disclosed; we do not describe the sample as random, representative, blind, or outcome-independently preregistered. The cross-version union of 69 scored identities is provenance only, not the primary sample or a pooled mutation denominator.

Locations. Abstract; Section 4.1, page 5; Tables 7 and 8, pages 7 and 7; Section 7, page 11.

R2.2. Justify why the twelve operators are representative of real Terraform defects using defect taxonomies.

Response. We have strengthened the justification while withdrawing the unsupported claim of representativeness. A new fault-model table distinguishes each group's motivating contract, cited empirical category or documented semantic mechanism, and inference boundary. For example, AWS documentation establishes what relaxing an IMDS token requirement means; the recorded Equinor example identifies the changed purge-protection default and its native-test context. These are more concrete motivations than an operator-family name alone, but they do not validate representative real-fault coverage. Generic Boolean inversion supplies 1,147 of 1,288 scored cases (89.1%); its

outcome is therefore not interpreted as a security-defect census. Family/subset tables expose this imbalance. The comment is addressed at the level of explicit fault-model justification, not a new real-fault validation experiment; real-fault coupling remains future work.

Locations. Section 3.2, page 3; the fault-model mapping in Table 4, page 4; Tables 9 and 12, pages 8 and 9; Section 6, page 10.

R2.3. A table with kill rate per operator and comparison with app code mutation testing papers.

Response. The revised operator table reports each of the sixteen frozen identifiers, including identifiers without scored targets, with generated/scored counts, assertion and runtime-error outcomes, survivors, exclusions, and the corresponding rates. Family and subset summaries prevent the pooled result from concealing Boolean dominance. The retained twelve supply 77 scored cases and the added four supply 1,211 under the same catalog 3 context; this partition is not a historical-version rerun or a causal comparison of operator quality. Related work now compares Oasis with application-code mutation research on mutant/real-fault coupling, coverage versus effectiveness, industrial use, and selective execution. The comparison identifies different goals, fault pools, fixtures, and filtering rather than ranking uncontrolled mutation percentages. No common adequacy threshold is inferred from application-code studies.

Locations. Section 2, page 2; Section 5.2, page 8; Tables 11, 9, and 10, pages 8, 8, and 8.

R2.4. The conclusion calls for routine adoption but there is no cost info and only 13 references.

Response. We have replaced the routine-adoption recommendation with a conditional diagnostic interpretation and added measured command costs. The cost table separates initialization, unmutated tests/validation, mutant validation, and mutant tests, reporting counts, elapsed-time sums, medians, and empirical nearest-rank 95th percentiles, including failures and timeouts. Primary mutant-test commands have a median of 11.59 seconds and a 95th percentile of 386.88 seconds. These are single recorded observations with warm caches and two execution lanes; summed command durations are not campaign wall time and omit some preparation, queue, and framework overhead. The expanded bibliography covers IaC defects, policy adoption, configuration/engine testing, equivalence, real-fault coupling, coverage, and mutation practice. We do not claim measured cost savings, a universally economical policy, or that more references alone resolve the scientific limitations.

Locations. Sections 4.5 and 5.4, pages 7 and 10; Table 14, page 10; Sections 2 and 8, pages 2 and 11; revised References ending on page 12.

Reviewer 3

R3.1. Not many mutants were actually run, hence the study is assessing coverage rather than assertions.

Response. We have expanded the execution account to 1,288 scored cases across 47 repositories and separated assertion kills from runtime-error rejection. Static potential reachability and historical reference labels are explicitly not dynamic coverage measurements. More executions alone do not establish oracle effectiveness, so we additionally report a separate fixed 123-case comparison: assertion detections rise from 39 to 73, with 34 gains and no losses. The treatment is accurately named source-informed test strengthening: it adds 63 assertions and 37 positive-control runs, including input expansion, so the gain is not an isolated assertion-only causal effect. Gains are concentrated: 32 of 34 concern S3 public-access-block mutations, and all twelve transfer-subset gains come from one repository. Prior pilot exposure, investigator-authored treatment, clustering, and the small transfer subset limit inference. The matched cases are never pooled with the primary campaign. We also disclose historical assertion-expression repairs and removal of constant-condition assertions, separate these from the no-new-adaptations catalog 3 policy, and provide a bounded repository ledger with unknown totals explicit.

Locations. Sections 3.3, 4.4 and 5.3, pages 3, 6 and 9; the existing native assertion example on page 9; Tables 11 and 13, pages 8 and 9; source-policy Table 6, page 6, and Section 6, page 10.

R3.2. Innovating by extending the operators to OpenTofu specific and module level constructs.

Response. This request is partially addressed, not fully fulfilled. Frozen catalog 3 extends supported module-input arguments and scalar defaults through `MUT-CFG-001`, alongside resource/local Boolean literals and improved effective caller/default analysis. The other added identifiers are `MUT-RES-004` (curated positive capacity/count to zero), `MUT-SEC-005` (scoped IMDS token requirement relaxation), and `MUT-SEC-006` (scoped EFS/Redshift encryption disabling). These additions have separately reported outcomes; the primary research pool is distinguished from

the native canary checks. However, shared HCL execution on OpenTofu is not an OpenTofu-specific semantic mutation family, and no such family has been implemented or evaluated. Arbitrary module interfaces, object/expression forms, and engine-specific rewrites remain outside scope. We state this limitation explicitly rather than describing execution compatibility or four additional operators as complete fulfillment.

Locations. Sections 3.2 and 3.3, pages 3 and 3; Tables 3 and 10, pages 4 and 8; Section 7, page 11.

R3.3. The execution cost of terraform test for each mutant is not discussed.

Response. We now report mutant-test invocation cost separately from mutant validation and setup, with individual timings and return codes retained in `command-events.csv`. There are 1,301 recorded primary mutant-test commands, including the thirteen timeout cases, compared with 1,288 scored cases. Their median is 11.59 seconds and nearest-rank 95th percentile is 386.88 seconds. The execution protocol specifies a 900-second initialization limit and 600-second test/validation limits. The phase table includes failed and timed-out commands and does not mislabel total per-case elapsed time as validation-plus-test time. Commands can overlap across two lanes; their sums are command time, not campaign wall time. Warm caches, single observations, excluded overhead, and long-running scopes limit extrapolation. The separate baseline timing probe is not included in primary costs, and no cross-engine performance advantage is inferred.

Locations. Section 4.2, page 5; Sections 4.5 and 5.4, pages 7 and 10; Table 14, page 10.

R3.4. How the surviving mutants relate to the misconfiguration findings of previous empirical work.

Response. We now connect the bounded access/encryption operators to the security-policy categories studied in prior Terraform work and distinguish these from broader IaC security smells and generic configuration faults. Recorded primary cases give the field edit and native outcome. Separate historical scanner examples include a native survivor with a new policy finding and an assertion kill without one. The historical comparison contains 88 such policy-flagged native survivors, but a scanner flag is not proof that a deployed resource is vulnerable. Interacting controls, inactive paths, mocks, irrelevant contracts, and unknown equivalence can all affect interpretation. With 89.1% of primary scored cases arising from generic Boolean inversion, we cannot project prior security-misconfiguration prevalence onto this survivor pool. The evidence supports contextualized test-sensitivity observations, not a validated cause assignment for every survivor or a real-vulnerability census.

Locations. Sections 2 and 3.2, pages 2 and 3; Tables 12 and 9, pages 9 and 8; Sections 5.4 and 6, pages 10 and 10.

R3.5. The conclusion is short and several references are arXiv preprints or incomplete.

Response. We have expanded the conclusion to state the primary outcomes, selected-baseline limitations, exclusions, incomplete execution, Boolean-family concentration, separate matched-case gain, and appropriate diagnostic interpretation. It no longer moves directly from a small sample to routine adoption. Bibliographic records have been checked and repaired with author information and published venues/persistent identifiers where verified, including the published ProTI and EMIaC records. Official tool documentation is identified as documentation rather than presented as peer-reviewed evidence. Future work now identifies engine-specific operators, richer expressions/interfaces, independent cohorts, real-fault validation, and repeated cost measurements as uncompleted research. Reproducibility claims distinguish locally retained research revisions and raw archives from an accessible public deposit; no new DOI or already-public release is asserted.

Locations. Sections 2, 7, and 8, pages 2, 11, and 11; Tables 7 and 13, pages 7 and 9; revised References ending on page 12.

Presentation and evidence

The original Procedia class/style and branding are retained. The pipeline figure is original, and an AI-assistance declaration is included. This response follows the article in the combined revision. Processed evidence accompanies the editable source; complete native archives require separate access. No similarity certification or completion of unperformed extensions is asserted.

Sincerely,
Tushar Teotia, Shiven Goomer, Yash Vardhan Rawat,
Minakshi Tomer, and Manoj Kumar Malik